

Question 1: Analyse packet1.pcap and find the flag.

Wireshark packet capture analysis of packet1.pcap. The packet list shows an ICMP Echo (ping) reply in packet 26. The packet details pane shows the ICMP Echo (ping) reply with a data field containing a Base64-encoded string. The packet bytes pane shows the raw data of the ICMP Echo (ping) reply.

ICMP packet details reveal a string

The string “U1VDVE YyMDIze2 FpX2IzX2 Nvb2x9” appear and need to decode by using Base64.

Decode from Base64 format
Simply enter your data then push the decode button.

U1VDVEYyMDIze2 FpX2IzX2Nvb2x9

For encoded binaries (like images, documents, etc.) use the file upload form a little further down on this page.

UTF-8 Source character set.

☐ Decode each line separately (useful for when you have multiple entries).

☒ Live mode OFF Decodes in real-time as you type or paste (supports only the UTF-8 character set).

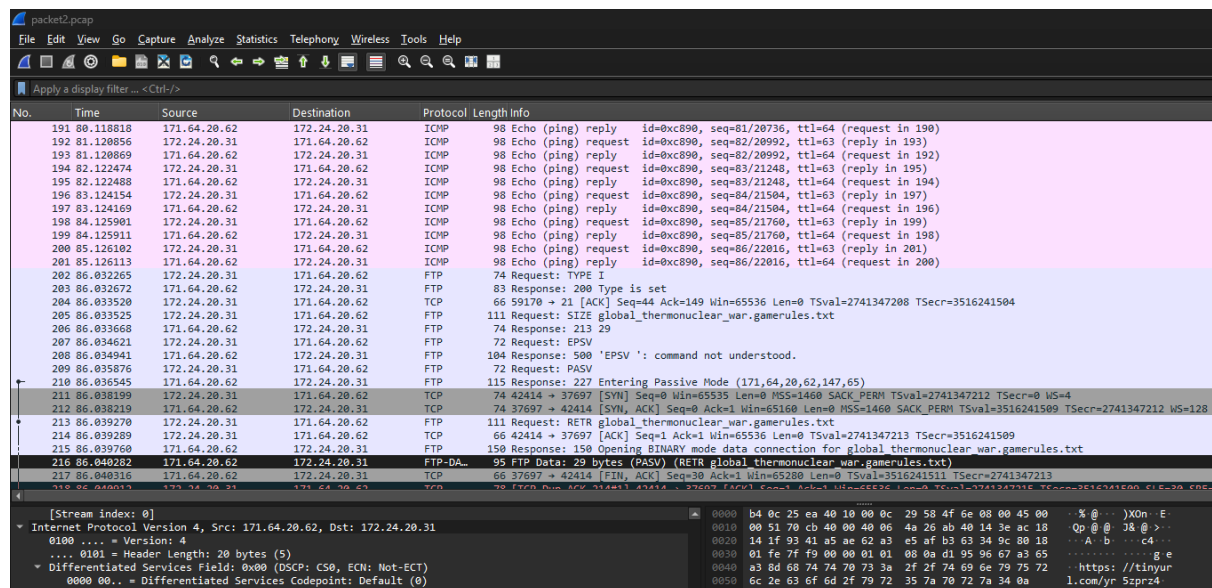
< DECODE > Decodes your data into the area below.

SUCTF2023{ai_is_cool}

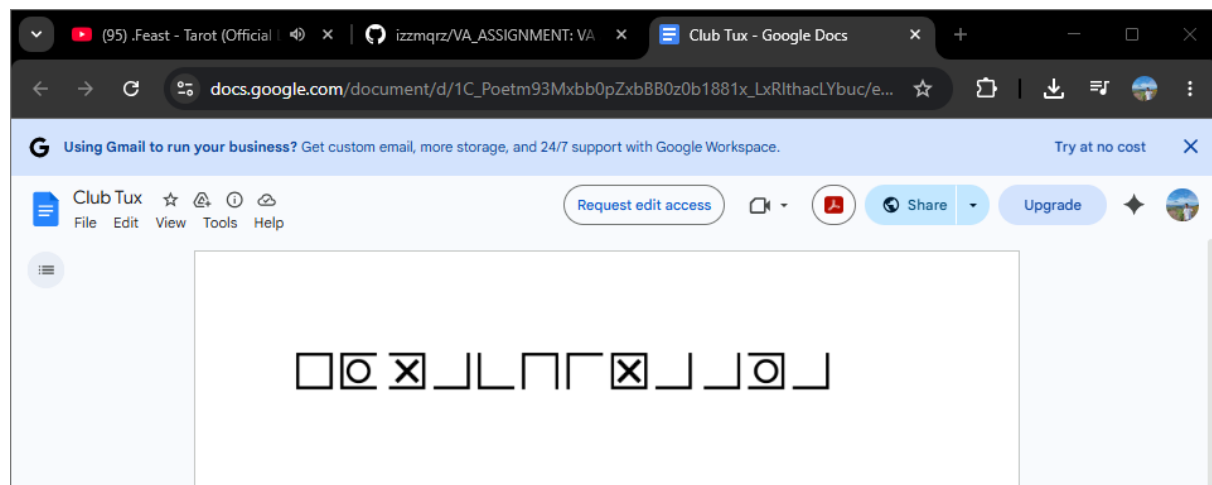
By using Base64 encoding, we finally successfully found the flag. The flag is SUCTF2023{ai_is_cool}

Question 2: Analyse packet2.pcap and find the flag.

In second packet file, traffic analysis revealed activity over TCP protocol, particularly involving HTTP communication



Url has found, the URL is directing to a Google Docs



Question 3: Interpret an Nmap Output

PORT STATE SERVICE VERSION

21/tcp open ftp vsftpd 2.3.4

22/tcp open ssh OpenSSH 5.3p1

80/tcp open http Apache 2.2.8

139/tcp open netbios-ssn

445/tcp open microsoft-ds Windows 7 Professional 7601 Service Pack 1

Questions:

1. What can an attacker do with each port?

- **Port 21 (FTP):** An attacker can attempt to intercept unencrypted credentials or exploit the specific software version to gain unauthorized file access.
- **Port 22 (SSH):** Attackers may attempt brute-force attacks to gain remote shell access or exploit vulnerabilities in the specific OpenSSH version.
- **Port 80 (HTTP):** This allows for web-based attacks such as Cross-Site Scripting (XSS), SQL injection, or exploiting outdated server modules.
- **Port 139/445 (SMB):** These are often targeted for lateral movement, unauthorized access to network shares, or remote code execution (RCE).

2. What vulnerabilities are likely present based on the version?

- **vsftpd 2.3.4:** Highly likely to contain the Backdoor Command Execution vulnerability (CVE-2011-2523) if it is the infamous compromised version.
- **Apache 2.2.8:** This version is very old and susceptible to multiple vulnerabilities, including **Slowloris DoS** and various module-specific exploits.
- **Windows 7 (SMB):** Being an unpatched Windows 7 system (Service Pack 1), it is critically vulnerable to **EternalBlue (MS17-010)**.

3. Which one is the highest risk and why?

- **The SMB (Port 445) on Windows 7 is the highest risk.**

Reason: It allows for Remote Code Execution (RCE) with System-level privileges without requiring user interaction. It is also "wormable" meaning an attack could spread automatically to other machines on the network

4. What attack path can be built from this?

- **Reconnaissance:** Identify the target as an unpatched Windows 7 machine via Nmap
- **Exploitation:** Use a framework like Metasploit to launch the EternalBlue exploit against Port 445
- **Post-Exploitation:** Gain a Meterpreter shell, dump credentials (hashdump) and move laterally to other systems using the credentials found in memory

5. What should be the remediation?

- **Update/Patch:** Immediately apply the **MS17-010** security update or upgrade to a supported OS (Windows 10/11)
- **Disable Unnecessary Services:** Disable SMBv1 and close Port 21 if FTP is not strictly required
- **Upgrade Software:** Update Apache and OpenSSH to the latest stable versions

Question 4: Identify the OS (OS Fingerprinting) – TTL

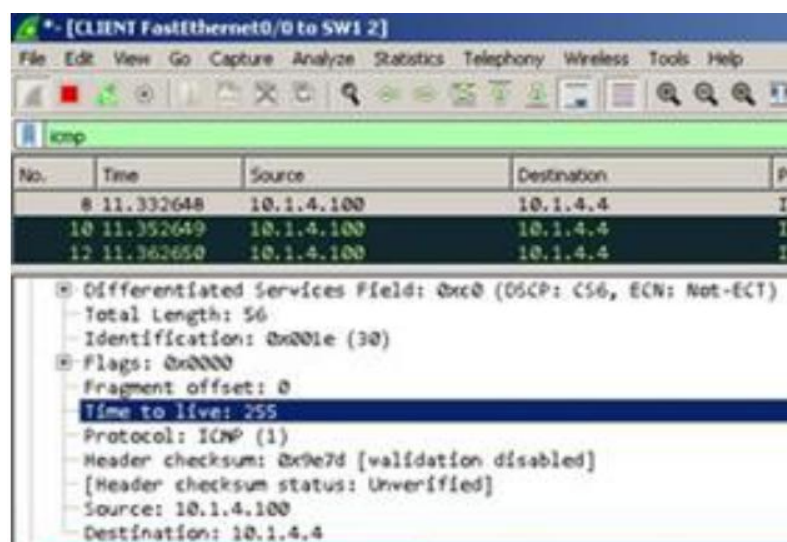
Image 1

```
[sk@ostechnix ~]$ ping -c5 localhost
PING localhost (localhost (:::1)) 56 data bytes
64 bytes from localhost (:::1): icmp_seq=1 ttl=64 time=0.063 ms
64 bytes from localhost (:::1): icmp_seq=2 ttl=64 time=0.057 ms
64 bytes from localhost (:::1): icmp_seq=3 ttl=64 time=0.070 ms
64 bytes from localhost (:::1): icmp_seq=4 ttl=64 time=0.067 ms
64 bytes from localhost (:::1): icmp_seq=5 ttl=64 time=0.056 ms

--- localhost ping statistics ---
5 packets transmitted, 5 received, 0% packet loss, time 4096ms
rtt min/avg/max/mdev = 0.056/0.062/0.070/0.005 ms
```

Answer: Linux

Reason: The terminal output shows a TTL value of **64**. Most modern Linux distributions and Unix-based systems (like macOS) use a default starting TTL of 64.



Answer: Cisco Router / Network Infrastructure

Reason: The Wireshark packet analysis displays a TTL value of **255**. This maximum possible TTL value is the standard default for many Cisco devices and specialized network hardware.

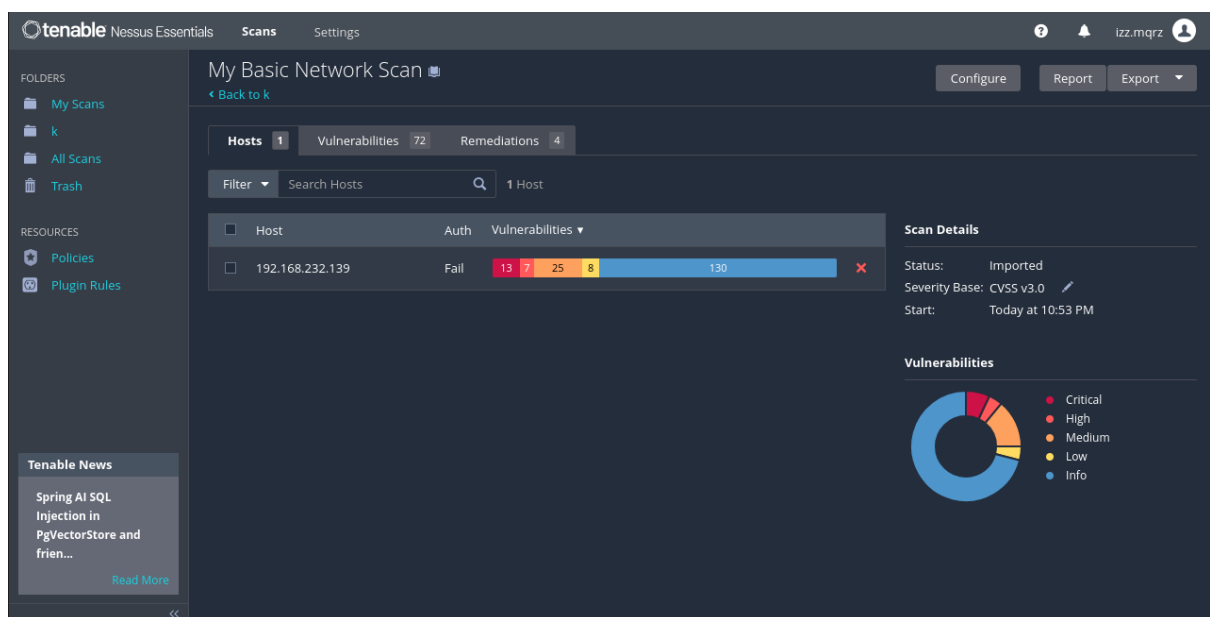
```
64 bytes from 192.168.122.239: icmp_seq=1 ttl=128 time=6.85 ms
64 bytes from 192.168.122.239: icmp_seq=2 ttl=128 time=0.510 ms
64 bytes from 192.168.122.239: icmp_seq=3 ttl=128 time=0.601 ms
64 bytes from 192.168.122.239: icmp_seq=4 ttl=128 time=0.541 ms
64 bytes from 192.168.122.239: icmp_seq=5 ttl=128 time=0.558 ms
```

Answer: Windows

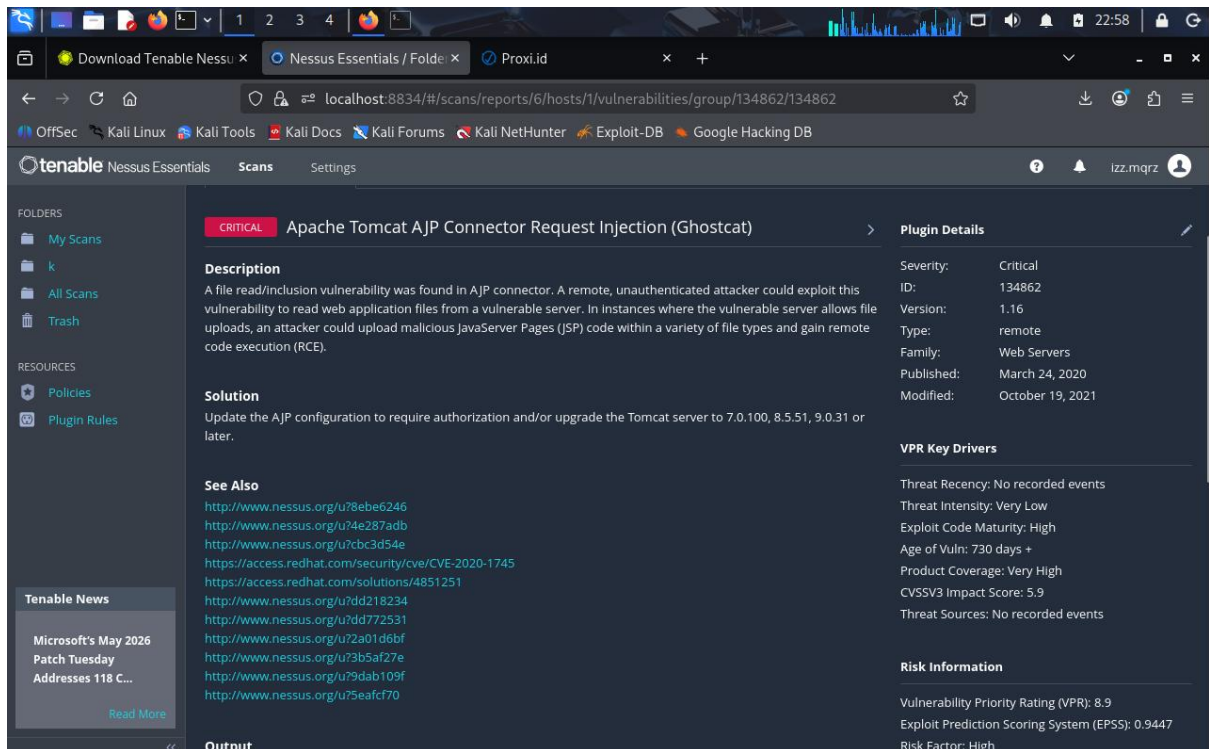
Reason: The ping results show a TTL value of 128. Microsoft Windows operating systems consistently use a default starting TTL of 128.

Question 5: Analyse the Nessus file

Upload to your nessus (Network_Scan.nessus) and analyse the files. Focus on critical or high findings that was identifies in analysis named "Ghostcat".



The file Network_scan.nessus was imported to Nessus successfully



Successfully found vulnerability for Ghostcat

1. **Affected port number:** 8009
2. **Affected Protocol:** Apache Tomcat AJP Connector Request Injection (GHOSTCAT)
3. **CVSS Score of vulnerability found:** 9.8 (Critical)
4. **Can you find any exploit related to this vulnerability?**

Vulnerability Information

CPE: cpe:/a:apache:tomcat
 Exploit Available: true
 Exploit Ease: Exploits are available
 Patch Pub Date: March 1, 2020
 Vulnerability Pub Date: March 1, 2020
 Exploited by Nessus: true

5. **Find CVE for this vulnerability.**

Reference Information

CVE: [CVE-2020-1938](#), [CVE-2020-1745](#)